

Given the inherent limitations of legacy protocols like Modbus, security must default to zero trust—continuously verifying every interaction and operating under the assumption of breach. To prevent the unauthorised siphoning of telemetry, every connected asset must be issued a unique digital identity through Public Key Infrastructure (PKI). By assigning each device a cryptographic certificate, we ensure that every communication is authenticated. This makes it possible to verify that a command—such as one sent to a Programmable Logic Controller (PLC)—originates from a verified, authorised source rather than a compromised endpoint or an adversarial ‘digital twin’ attempting to exfiltrate data.

Having explored the challenges and potential mitigation approaches, the next step is to anchor them within a structured framework. The Purdue Model and D5 strategy together provide a practical blueprint for implementing layered, resilient security.

The architectural blueprint

The Purdue Model organises industrial control systems into hierarchical layers, enabling a structured approach to system design, operation, and security. By segmenting the environment into distinct levels, it helps isolate risks, enforce controlled communication between layers, and improve manageability through modular architecture.

Level 0: This is the ‘Ground Truth’ of the ICS (industrial control system) environment. It consists of the physical devices—sensors and actuators—that directly interact with the production environment. While sensors (like thermocouples or pressure transducers) read physical conditions, actuators (like valves, motors, or heaters) perform the physical work based on commands from above.

Level 1: At this level, controllers like PLCs take inputs from sensors and make real-time decisions to

control industrial processes. Based on programmed logic, they send commands to actuators—for example, adjusting valves to regulate flow or triggering cooling systems when temperature exceeds a threshold. Communication usually happens over industrial protocols such as Modbus, enabling reliable interaction between field devices and controllers.

Level 2: Supervisory control (SCADA & HMI): This layer transitions from individual machine logic to broad process oversight. SCADA (Supervisory Control and Data Acquisition) systems aggregate data from multiple PLCs to provide a birds-eye view of an entire assembly line or shop floor. While PLCs handle the millisecond-by-millisecond logic, SCADA allows operators to perform high-level monitoring, setpoint adjustments, and system-wide calibrations.

In large-scale plants, this layer is often distributed. Local SCADA nodes may manage specific areas (like chemical processing vs packaging), often dictated by different equipment vendors. These local nodes then feed a master SCADA in a central control room for plant-wide orchestration.

Parallel to this, HMIs (Human-Machine Interfaces) serve as the localised, ‘hardened’ access points. Unlike a central SCADA, an HMI is typically dedicated to a single machine, providing operators with immediate, touch-screen control in rugged environments where a standard computer would fail.

Level 3: This level is responsible for managing and optimising plant operations. It includes systems such as SCADA servers (real-time monitoring and supervisory control), Historians (time-series data storage and trend analysis), and Manufacturing Execution Systems (MES), which manage production workflows, track work orders, enforce quality processes, and monitor performance metrics such as throughput and efficiency on the shop

floor. These systems aggregate and contextualise data from Level 1 and Level 2, supporting functions such as production monitoring, process optimisation, and operational decision-making within the plant environment.

The IDMZ (industrial demilitarised zone) acts as a buffer zone between OT (Level 3) and enterprise IT (Level 4). It hosts intermediary systems such as data historians (replicas). Data from the plant network is replicated or forwarded into the IDMZ, where it can be securely accessed by enterprise systems like ERP for reporting and analytics. Communication across this boundary is strictly controlled, often using firewalls, and in some cases unidirectional gateways to enforce one-way data flow.

Level 4: This primary IT domain hosts corporate systems like ERP, CRM, and business intelligence (BI) tools. Level 4 consumes filtered operational data from Level 3 through the IDMZ to synchronise factory output with business demand.

Raw plant data gets aggregated and processed into high-level KPIs, such as OEE (overall equipment effectiveness), cost per unit, supply chain readiness, and inventory turns. Communication flows bi-directionally: Level 4 pushes ‘what to build’ (e.g., production orders) down to the factory, while lower levels report ‘how it was built’ (actual production results).

Level 4 sends not just ‘what to build’ (production orders) but also optimisations—like demand forecasts, recipe tweaks, or scheduling adjustments—down to Level 3. In return, Level 3 reports ‘how it was built’ (actual KPIs and production data) upward through the IDMZ.

Level 5: This level represents connectivity to external systems beyond the enterprise, such as cloud platforms, third-party services, and external partner networks. While not part of the original Purdue Model, it is commonly included in modern architectures to